SIGPN-T — Tableau de traçabilité des 30 anomalies (biométrie, version 1.2)

Police nationale du Tchad — Éditeur : TECHNOTCHAD — 11 novembre 2026 — Anomalie → étape → correction → composants → risque résiduel → validation

Ordre des étapes : celui du rapport de revue (1 à 10). Statut de la revue = statut attribué à la version 1.1. **Statut de la version 1.2 : corrigé en conception, à valider par les trois validateurs externes.**

N°	Gravité	Statut de la revue	Étape	Chapitre	Correction (résumé)	Composants	Risques résiduels	Validations nécessaires
A-01	Critique	NON VALIDÉ	1	5	Cinq rôles PostgreSQL distincts : propriétaire de schéma sans connexion ; migrateur utilisé seulement au déploiement ; rôle applicatif sans DDL, sans TRIGGER, sans TRUNCATE, ni superutilisateur, ni propriétaire ; rôle du service biométrique sur base dédiée ; rôle de sauvegarde en lecture seule.	deploy/docker-compose.yml, deploy/entrypoint.sh (migrations hors du conteneur applicatif), deploy/backup/*, prisma/schema.prisma (URL de migration distincte), src/server/db.ts (tripwire), src/server/env.ts, scripts SQL […]	Superutilisateur de secours existant (scellé, alerté) ; collusion de deux administrateurs ; le poste de développement conserve un superutilisateur (hors production)	Architecte sécurité externe (revue des rôles et de pg_hba) ; exécution des tests d'attaque en préproduction ; test d'intrusion ciblé
A-02	Critique	NON VALIDÉ	2	6	Registre biométrique chaîné (BiometricLedger) alimenté par des fonctions SECURITY DEFINER à chaque insertion de recherche, correspondance, revue, événement de contrôle et décision d'effacement : empreinte canonique de la ligne, chaînage (hash = SHA-256(prevHash ‖ seq ‖ type ‖ id ‖ rowHash ‖ date)), verrou consultatif comme pour AuditLog.	Nouvelles tables BiometricLedger, BiometricLedgerCheckpoint ; fonctions et déclencheurs ; service d'ancrage ; tâche de vérification ; src/server/audit-chain.ts (extension à l'ancrage) ; stockage externe à écriture seule	Compromission simultanée de la base, du HSM et du support externe ; fenêtre de 15 minutes couverte par l'expédition en temps réel mais non nulle	Architecte sécurité externe (preuve de la chaîne et de l'ancrage) ; essai de falsification par une équipe indépendante ; Responsable indépendant de la protection des […]
A-03	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Support externe à écriture seule dans un autre domaine d'administration (stockage à verrouillage d'objet, ou serveur de journaux dédié hors du périmètre des administrateurs de la plate-forme) ; fréquence : temps réel (empreintes), 15 min (points de contrôle signés), quotidienne (ancrage horodaté) ; vérificateur : auditeur + responsable […]	Service d'ancrage (nouveau), deploy/*, procédure d'exploitation	Dépendance au tiers d'horodatage ; coût du stockage externe	Architecte sécurité externe ; Responsable indépendant de la protection des données
A-06	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Liste exhaustive : BiometricSearch — aucune colonne modifiable pour les lignes réelles (insertion seule) ; pour les lignes isDemo = vrai seules les colonnes historiques action, actionNotes, actionById, actionAt restent modifiables ; isDemo est immuable dans tous les cas (déclencheur).	prisma/schema.prisma (migrations additives), déclencheurs, biometric/service.ts	Les anciennes lignes DEMO restent modifiables (comportement conservé volontairement)	Architecte sécurité externe ; tests d'attaque (UPDATE de chaque colonne, bascule de isDemo)
A-07	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Pour les contrôles réels (isSimulation = faux) : ligne insertion seule ; transitions d'état dans BiometricControlEvent (insertion seule) ; décision humaine uniquement dans BiometricReview ; les champs reviewed* du contrôle deviennent dérivés en lecture seule.	biometric/control.ts, biometric/review.ts (nouveau), queries.ts, écran de contrôle	Période de double lecture (anciens et nouveaux champs) jusqu'à la fin de la phase 6	Architecte sécurité externe ; non-régression tests/integration/biocontrol.test.ts

TECHNOTCHAD

A-04	Majeure	NON VALIDÉ	3	7	Restauration biométrique à double contrôle natif : les sauvegardes sont chiffrées par une clé de sauvegarde enveloppée par le HSM, déchiffrable seulement avec le quorum de gardiens (2 sur 3).	deploy/backup/*, procédure de restauration (nouvelle), service d'ancrage, HSM	Fenêtre de perte des données postérieures au point de restauration (inévitable) ; disponibilité du quorum de gardiens	Architecte sécurité externe ; exercice de restauration observé par l'auditeur ; Responsable indépendant de la protection des données
A-05	Majeure	NON VALIDÉ	3	7	Registre d'effacement répliqué en continu hors de la base (journal externe à écriture seule, entrées signées par le HSM : identifiant, date, décision du responsable de la protection des données), conservé au moins 125 jours (35 jours de sauvegarde + 90 jours de marge ; recommandation : 1 an).	BiometricErasureRegister (table + miroir externe), biometric/retention.ts (nouveau), procédure de restauration	Délai entre l'effacement et la réplication (fermé par la réplication synchrone du miroir)	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Juriste (valeur de la « mise hors d'usage » en sauvegarde)
A-16	Moyenne	VALIDÉ SOUS RÉSERVE	3	7	Base biométrique dédiée (cluster ou base distincte, rôle distinct) ; sauvegarde principale de l'application exclut le schéma biométrique ; sauvegarde biométrique séparée, verrouillage d'objet à 35 jours, clé de sauvegarde détruite à l'échéance ; contrôle automatique que la sauvegarde principale ne contient aucune table biométrique.	deploy/backup/*, deploy/docker-compose.yml, configuration de la base biométrique	Deux cycles de sauvegarde à exploiter	Architecte sécurité externe ; contrôle de l'auditeur
A-11	Majeure	NON VALIDÉ	4	8	Service biométrique séparé (processus, identité, hôte et réseau distincts) : l'application web n'a jamais accès aux clés ni aux échantillons en clair ; API étroite (recevoir une capture, inscrire, rechercher, matériel de revue éphémère, effacer) sans point de déchiffrement en masse.	Nouveau service biométrique, biometric/vault.ts (déplacé dans le service), src/server/biometric/service.ts (client), deploy/*	Compromission du service biométrique lui-même (surface réduite, quotas limitant l'exfiltration)	Architecte sécurité externe ; test d'intrusion visant l'exfiltration massive
A-12	Majeure	VALIDÉ SOUS RÉSERVE	4	8	Quorum natif du HSM (carte à puce, 2 sur 3 au minimum) pour générer, détruire une clé maîtresse et déchiffrer les sauvegardes ; rôles HSM séparés (officier de sécurité, officier de chiffrement, auditeur) tenus par des personnes différentes ; deux HSM synchronisés ; niveau d'assurance exigé (D-21).	HSM (nouveau), service de clés, procédure de cérémonie	Perte simultanée de gardiens (≥ 3 titulaires, séquestre)	Architecte sécurité externe ; audit de la cérémonie ; D-21
A-13	Moyenne	VALIDÉ SOUS RÉSERVE	4	8	Chapitre complet (états, rotation, compromission, panne et remplacement du HSM, séquestre, départ d'un gardien, agilité cryptographique).	biometric/vault.ts, key-service.ts, procédures	Erreur humaine en cérémonie (exercices annuels)	Architecte sécurité externe ; exercice de compromission simulée
A-19	Majeure	NON VALIDÉ	5	9	Identité d'agent (StaffIdentity) vérifiée sur pièce, unique par personne physique, rattachée à la fiche agent et au compte.	Nouvelle table StaffIdentity, Officer, User (liaison), admin/users.ts, approvals/*, biometric/review.ts	Pièce d'identité falsifiée ou complicité à l'enregistrement	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Direction (D-04)
A-20	Majeure	NON VALIDÉ	5	9	Épinglage : chaque droit de gouvernance n'est attribuable qu'à son profil (contrôle dans le code d'édition de rôles et dans l'exécuteur d'approbation, et déclencheur de base sur RolePermission) ; matrice d'éligibilité par type d'approbation : les nouveaux types exigent biometric:governance_approve de deux identités et de deux profils […]	rbac/permissions.ts, roles.ts, grants.ts, admin/roles.ts, approvals/rules.ts et service.ts, déclencheur sur RolePermission	Modification du code par un développeur (contrôle de version et revue)	Architecte sécurité externe ; revue du code d'approbation

TECHNOTCHAD

A-21	Moyenne	VALIDÉ SOUS RÉSERVE	5	9	Attribution uniquement par une demande approuvée par le commandement national et le responsable de la protection des données ; l'administrateur de sécurité ne peut ni créer ni attribuer ces profils ; premier titulaire désigné par décision écrite de la Direction lors d'une cérémonie d'amorçage témoin et journalisée.	rbac/grants.ts, approvals/*, procédure d'amorçage (nouvelle)	Amorçage fondé sur la confiance en la décision écrite	Direction ; Responsable indépendant de la protection des données
A-22	Moyenne	VALIDÉ SOUS RÉSERVE	5	9	Liste des tests à adapter (sensibilité, libellés FR/AR, matrice de routes, décomptes de documentation) ; la réponse de l'historique porte un champ visibility explicite (FULL pour les lignes DEMO, METADATA ou FULL selon le profil pour les lignes réelles) ; test de contrat versionné.	tests/unit/sensitivity.test.ts, tests/security/route-matrix.test.ts, biometric/queries.ts, i18n	Oubli d'un test lors de l'implémentation (liste de contrôle)	Architecte sécurité externe ; revue de la liste de tests
A-14	Moyenne	NON VALIDÉ	6	10	Table BiometricSampleBasis (échantillon ↔ affaire ou décision, début, fin) ; échéance = maximum des bases actives ; les événements de conservation sont émis par les statuts de partie (CLEARED, CHARGED…) et les issues d'affaire ; effacement seulement quand plus aucune base n'est active ; calcul documenté et testé.	Nouvelles tables, cases/service.ts, persons/service.ts (émission d'événements), biometric/retention.ts	Qualification juridique des bases (à confirmer)	Juriste ; Responsable indépendant de la protection des données
A-15	Moyenne	DÉCISION REQUISE	6	10	Règle de précédence proposée : la conservation de preuve judiciaire l'emporte tant que l'affaire est ouverte, mais ne porte que sur la copie probatoire (pièce avec chaîne de possession) ; l'échantillon de référence opérationnel est effacé selon la politique ; toutes les copies sont inventoriées et rattachées au registre d'effacement ; […]	evidence/service.ts, retention.ts, registre d'effacement	Désaccord d'interprétation juridique	Juriste ; Responsable indépendant de la protection des données ; Justice
A-08	Majeure	NON VALIDÉ	7	11	Procédure réordonnée : conformité (données synthétiques) → évaluation indépendante → approbation en mode ombre → ré-inscription par lot → double fonctionnement → approbation de bascule.	BiometricProvider, BiometricSample, BiometricEnrollment, BiometricJob, orchestrateur, déclencheurs	Erreur d'étiquetage de la classe de données (contrôles automatiques et audit)	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données
A-09	Majeure	VALIDÉ SOUS RÉSERVE	7	11	Essai bi-fournisseur en phase 3 : ré-inscription d'un jeu synthétique ou sous licence de l'AFIS A vers l'AFIS B depuis les images, et mesure de l'écart de précision (critère : dégradation relative du FNMR ≤ [20 %] au même FMR) ; test d'échange de gabarits normalisés documenté ; clause du marché imposant au soumissionnaire de fournir un […]	Plan de tests, cahier des charges, outil de ré-inscription	Perte de précision inévitable sur gabarit normalisé (l'image est la voie de référence)	Évaluateur indépendant ; Architecte sécurité externe
A-23	Moyenne	NON VALIDÉ	8	12	Tous les critères sont réécrits avec vérité terrain (jeu étiqueté, contre-expertise d'un échantillon aléatoire, sondes pièges), bornes de confiance à 95 % (règle des trois : zéro événement sur n essais indépendants borne le taux à $3/n$) et tailles d'échantillon minimales ; la phase 1 est scindée en 1a (sans HSM) et 1b (avec HSM).	Plan de déploiement, plan de tests	Représentativité du jeu d'évaluation	Évaluateur indépendant ; Architecte sécurité externe ; Direction

TECHNOTCHAD

A-24	Majeure	NON VALIDÉ	8	12	Nouvelle phase 3b « collecte encadrée » : base légale en vigueur, analyse d'impact, responsable de la protection des données indépendant, consentement, coffre dédié (classe EVALUATION_CONSENTED), service biométrique et HSM opérationnels, destruction programmée du jeu.	Plan de déploiement, BiometricLegalBasis, coffre	Consentement de personnes en situation de dépendance (à encadrer par éthique)	Juriste ; Responsable indépendant de la protection des données ; comité d'éthique
A-25	Moyenne	VALIDÉ SOUS RÉSERVE	8	12	Cinq classes de retour arrière : R0 (drapeau ou configuration), R1 (version logicielle compatible avec les données), R2 (restauration, double contrôle), R3 (bascule de fournisseur), R4 (ré-enveloppement en deux temps : l'ancienne génération de clé reste active jusqu'à vérification).	Plan de migration, procédures, prisma/ migrations futures	Retour partiel après des données réelles (par conception)	Architecte sécurité externe
A-26	Moyenne	VALIDÉ SOUS RÉSERVE	8	12	Revue en aveugle d'abord (comparaison sans score ni rang), sondes pièges (≥ 2 % des revues, correspondances et non-correspondances connues), temps minimal de revue, filigrane du relecteur sur l'écran, double relecture pour les décisions menant à une mesure coercitive, indicateurs (taux d'infirmation, sensibilité et spécificité sur les […]	biometric/review.ts, écrans de revue, tableau de bord de qualité	La capture d'écran ne peut pas être empêchée (le filigrane dissuade)	Évaluateur indépendant ; Responsable indépendant de la protection des données
A-10	Majeure	DÉCISION REQUISE	9	13	D-03 devient contraignant : option B obligatoire (gabarit normalisé + propriétaire + échantillon de référence chiffré) ; toute autre option = portabilité non garantie, projet suspendu tant que le risque n'est pas accepté par écrit.	Modèle de données (échantillon), cahier des charges, D-03	Volume de stockage des images	Direction ; Juriste ; Évaluateur indépendant
A-17	Majeure	DÉCISION REQUISE	9	13	attest() supprimé.	NationalRegistryConnector, BiometricSubjectLink	Évolution du cadre légal	Direction ; Juriste ; Responsable indépendant de la protection des données (D-07)
A-18	Moyenne	VALIDÉ SOUS RÉSERVE	9	13	Matrice des flux (direction, contenu, base légale, état par défaut) ; procédure de scission (sujet suspendu pour toute attribution positive, attribution de chaque échantillon par deux relecteurs, délai de 30 jours, mise en quarantaine à défaut) ; pseudonyme par système = HMAC à clé non exportable du HSM ; mode dégradé (enrôlement avec […]	NationalRegistryConnector, BiometricIdentityEvent, persons/service.ts	Spécifications du dossier unique encore inconnues	Architecte sécurité externe ; Juriste ; porteur du dossier unique
A-27	Moyenne	DÉCISION REQUISE	9	13	Ajout de D-17 à D-23 (mineurs, échanges internationaux, valeur probante et corroboration, statut du responsable de la protection des données, assurance du HSM, accès du parquet, exploitation et enquête de connectivité) ; recommandations de D-02, D-03, D-04, D-05, D-06, D-07, D-08, D-11, D-13 ajustées.	Registre des 23 décisions	Décisions tardives	Direction ; Juriste

TECHNOTCHAD

A-28	Moyenne	VALIDÉ SOUS RÉSERVE	10	14	Registre à 25 risques avec échelle probabilité × impact, classes Bloquant / Critique / Élevé / Moyen / Faible, niveau brut et résiduel, propriétaire.	Registre des risques	Risques non identifiés	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données
A-29	Mineure	VALIDÉ SOUS RÉSERVE	10	14	Checklist remplacée par trois checklists de validation externe (architecte sécurité, juriste, responsable indépendant de la protection des données) avec preuves attendues ; l'auteur n'évalue pas ses propres critères.	Chapitre 14.3	—	Les trois validateurs externes
A-30	Mineure	VALIDÉ SOUS RÉSERVE	10	14	BiometricMatch : subjectId obligatoire pour les lignes réelles, personId interdit ; BIOMETRIC_MODE scellé (modification = redéploiement approuvé + alerte, lecture seule pour l'application) ; clés d'idempotence conservées 24 h puis purgées ; filigrane pour la comparaison éphémère ; contrôle d'intégrité de la configuration au démarrage.	env.ts, orchestrateur, schéma	—	Architecte sécurité externe

TECHNOTCHAD